

FROM PASSWORDS TO PASSKEYS

An interactive guide to authentication, phishing and MFA

Name: _____ zID: _____

Teach Something · beginner audience · 5-minute presentation

System
e sign-in

MFA · Passkeys

CLAIM

I am

PROOF

Pass

DECISION

Allow

Login security fails when three decisions blur together

The project teaches the boundary before it teaches the technology.

IDENTITY

Who is the account about?

Record / claim

AUTHENTICATION

What proof is accepted now?

Password / key

AUTHORISATION

What may the session do?

Scope / privilege

Goal

Enable a beginner to diagnose the failed layer, choose a control that changes the attack path, and explain residual risk.

Four modules turn an attack chain into decisions

The website stores progress locally and exports anonymous learning evidence.

A/ AuthLab

Learn

Passkeys

Results

Local-only session

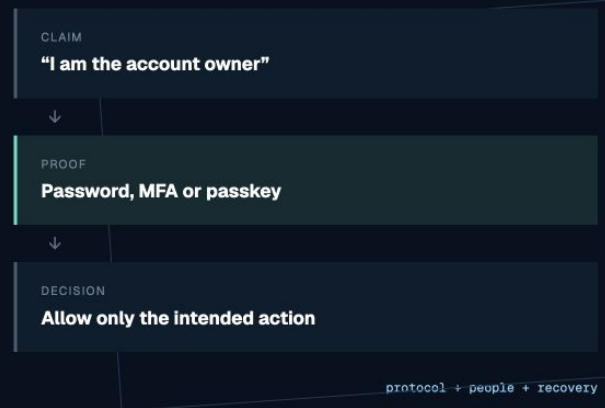
INTERACTIVE SECURITY ENGINEERING GUIDE

Stop memorising login advice. See the system behind it.

Explore how identity is proved, how phishing steals reusable secrets, where MFA breaks, and why passkeys change the protocol—not just the user interface.

Start with the pre-test

No real usernames, passwords or MFA codes are requested.



01

Separate the layers

02

Trace credential stuffing

03

Inspect origin and context

04

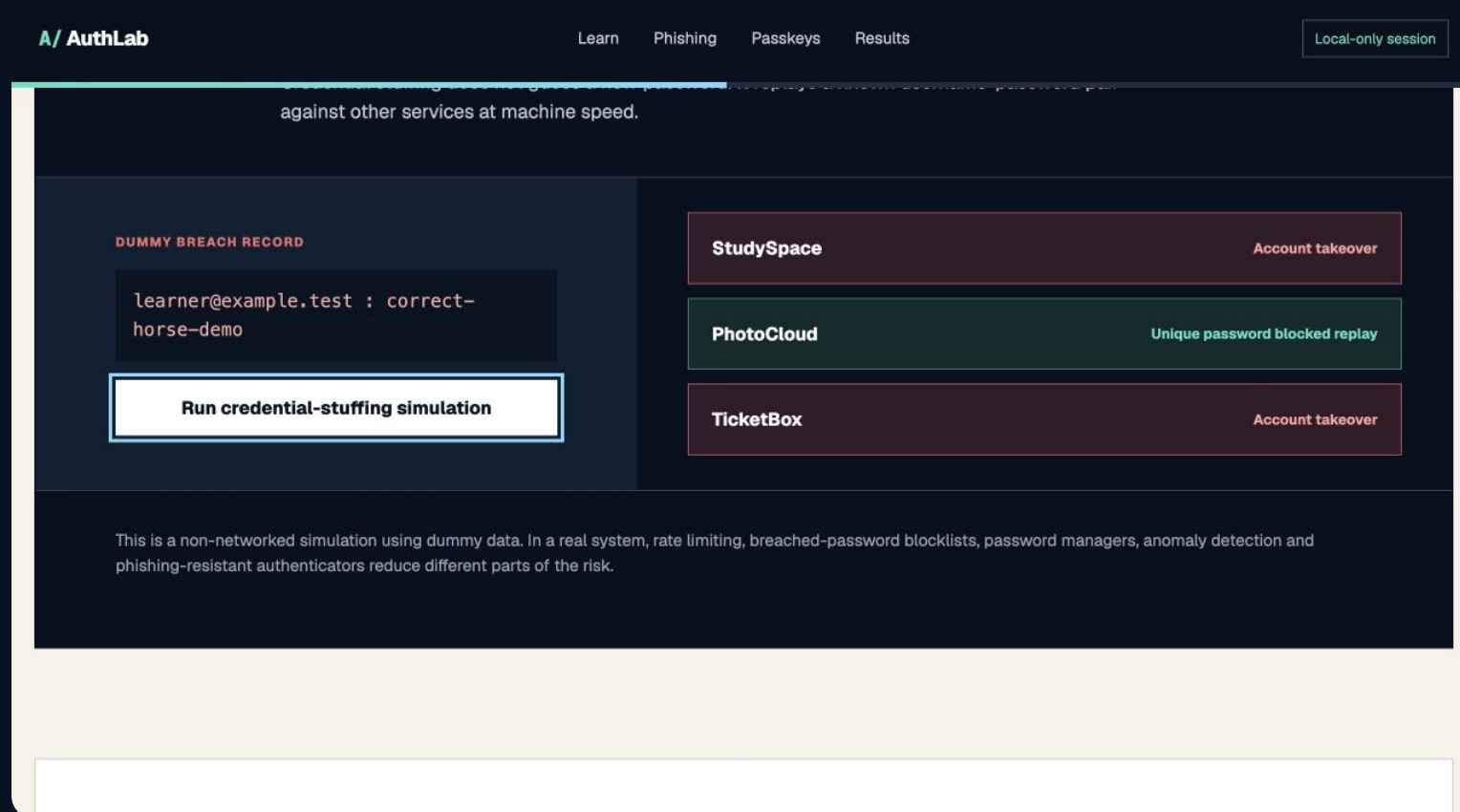
Compare MFA with passkeys

OUTPUT

Pre/post score · scenario answers · confidence · reflection

A strong reused password is still replayable proof

The simulation changes one variable and makes two account takeovers visible.



1

Exposure

Breach detection + notification

2

Automated replay

Rate limits + bot signals

3

Cross-service acceptance

Unique or non-replayable proof

Control the protocol, not only the string.

A copied logo is weak evidence; the registered domain is decisive

Four scenarios force an evidence-based action before revealing feedback.

A/ AuthLab Learn Phishing Passkeys Results Local-only session

03 PHISHING AND IMPERSONATION

Read the registered domain from right to left

Logos, padlocks and polished layouts can be copied. The origin is the security boundary that a fake page cannot simply choose.

FROM
IT Service Desk <support@example.edu>

Security key registration is now available

<https://accounts.example.edu/security-keys>

Legitimate **Phishing**

Correct. The registered domain is example.edu and the path is plausible.

FROM
Campus Account Team <urgent@account-notice.example.net>

Your mailbox closes in 20 minutes

<https://example.edu.verify-login.example.net/session>

Legitimate **Phishing**

Correct. The registered domain is example.net; example.edu only appears in a subdomain.

DECISION RULE

**Inspect origin.
Use a trusted route.
Verify context.
Report safely.**

Why this matters

Passwords and real-time OTPs can be relayed. A trustworthy-looking interface cannot prove which verifier receives the secret.

Passkeys resist phishing by binding proof to the relying party

The private key stays with the authenticator; a look-alike origin cannot obtain a valid assertion.

A/ AuthLab

Learn

Phishing

Passkeys

Results

Local-only session

04

MFA AND PASSKEYS

More factors do not always mean phishing resistance

OTPs and push prompts improve a password-only flow, but an attacker-controlled page can still relay a code or pressure a user to approve.

METHOD	CREDENTIAL STUFFING	REAL-TIME PHISHING	FATIGUE	SECURITY PROPERTY
Password	High	High	N/A	Shared secret
SMS OTP	Medium	High	Low	Code can be relayed
Authenticator OTP	Low	High	Low	Code can be relayed
Push approval	Low	Medium	High	Fatigue / session relay
Passkey (WebAuthn)	Low	Low	Low	Origin-bound public key

MECHANISM

PROOF

ORIGIN-BOUND

PASSWORD

replayable

NO

TOTP

short-lived

NO

PASSKEY

signed challenge

YES

Residual risk remains

Device compromise · recovery · ecosystem availability · excessive authorisation

The artefact works; learning evidence still needs participants

Functional evidence and human evidence are reported separately.

A/ AuthLab

LearnPhishingPasskeysResults

Local-only session

PRIVATE RESULTS

Your evidence belongs to you

Export a de-identified record for evaluation. The site stores progress only in your browser; nothing is uploaded automatically.

PRE-TEST	POST-TEST	CHANGE	MODULES
6 / 6	6 / 6	+0	4 / 4

How useful was this activity?

12345

Anonymous feedback (do not include names or contact details)

What became clearer? What was still confusing?

BUILD

PASS

Production build completed

PATH

PASS

Full learner journey tested

DATA

0

No participant results invented

Next: run the supplied pre/post protocol with 3–5 volunteers and report every outcome, including zero or negative change.

Security improves when the proof changes.

01

Diagnose

Separate identity, authentication and authorisation.

02

Interrupt

Place controls along the whole attack path.

03

Bind

Prefer origin-bound, non-replayable authentication.

[Interactive guide](#) · [workbook](#) · [report](#) · [90-second demo](#) · [editable slides](#)

[Open the project website to try it](#)

Questions?